

ADR-002: Security Controls

Status

Draft

Date

10 June 2026

Purpose

Document the security controls required to protect the SecOpsAI platform and its API services.

Security Controls

1. Authentication

Control: JSON Web Token (JWT)

Reason:

JWT will be used to verify user identity before granting access to API resources.

2. Authorization

Control: Role-Based Access Control (RBAC)

Reason:

RBAC ensures users can only access resources and functions permitted by their assigned roles.

3. Transport Security

Control: HTTPS/TLS

Reason:

All communications between clients and the API must be encrypted to protect data in transit.

4. Rate Limiting

Control: API Request Rate Limiting

Reason:

Rate limiting helps prevent abuse, brute-force attacks, and denial-of-service attempts.

5. Input Validation

Control: Server-Side Input Validation

Reason:

All incoming data must be validated to prevent injection attacks and malformed requests.

6. Audit Logging

Control: Security Event Logging

Reason:

Authentication attempts, API requests, and security events should be logged for monitoring and investigation.

7. Monitoring

Control: Prometheus and Grafana Monitoring

Reason:

Monitoring provides visibility into system health, performance, and potential security incidents.

8. Secrets Management

Control: Environment Variables

Reason:

Sensitive values such as API keys and database credentials should not be hardcoded into source code.

Decision Outcome

The above controls will be implemented as baseline security requirements for the SecOpsAI platform.

